数字依赖与组织韧性：地缘政治背景下网络风险的分析框架

Innocent Twagirumukiza • 2026年10月

摘要

背景。网络风险至今仍主要围绕组织自身管理的技术边界来界定。然而，近期的机构报告和多起重大事件表明，组织所面临的风险敞口还来自其无法控制的资源：软件供应商、服务中介、基础设施、硬件组件和算力。

目的。本文探讨：在什么条件下，外部依赖会成为网络风险传导的载体（包括该风险产生于地缘政治背景之时）；地缘政治维度在其中发挥何种作用；以及网络风险治理如何将其纳入考量。

方法。通过概念分析，提出五类依赖的类型学和五个维度的分析框架（依赖、集中度、可替代性、传导、韧性）。随后将该框架应用于公开资料中记录的六种情形：NotPetya 与马士基、SolarWinds、2015年乌克兰电网攻击、Change Healthcare、稀土，以及与人工智能相关的依赖。每个案例的地缘政治维度均给出证据等级。

结果。区分技术安全边界与依赖边界，使我们得以将性质迥异的事件放在一起解读。在所考察的案例中，一项依赖的关键性似乎更多地与供给集中度、替代时间以及降级模式的缺失相关，而与引发中断的行为者的性质关系较小。只有部分案例存在正式确立的地缘政治关联。

启示。本文向治理、风险与合规（GRC）职能提出六项方向，从绘制真实依赖图谱，到测试降级模式下的运行，再到将人工智能供应链纳入考量。

局限。本研究依赖公开文献资料、少量案例以及单一分析者的编码，未提供原创的实证验证。

关键词：网络安全；风险管理；数字依赖；组织韧性；地缘政治；供应链；治理；GRC。

1. 引言

1.1 背景与问题

大多数网络风险管理框架都从组织所管理的对象出发：工作站、服务器、应用、网络、身份和数据。这种做法是合理的，因为这是组织可以直接采取行动的边界。然而，一旦业务连续性依赖于该边界之外的资源——第三方发布的软件、基础设施服务、电信运营商、支付服务商、电子元器件、能源——这种做法就显得不够了。

战略环境加剧了这一局限。欧盟理事会在2026年3月16日的结论中强调，恶意网络活动往往是更广泛的混合行动的重要组成部分，这些行动由国家行为者或充当国家代理人的非国家行为者实施（Council of the European Union, 2026, point 12）。欧盟网络安全局（ENISA）在其2026年威胁态势报告中指出，针对数字依赖的攻击，包括针对供应链和第三方的攻击，通常会引发大规模或高影响的事件（ENISA, 2026a; ENISA, 2026b）。公共行政部门是遭受攻击最多的行业，占2025年记录案例的32%（ENISA, 2026b）。

由此可见，组织无需成为攻击目标也会暴露于风险之中。一家并无特殊政治或军事利益的企业，仍然身处某个生态系统之中：它依赖云服务商、电信运营商、服务提供商、境外开发的软件、能源供应商和银行。这些行为者中任何一方遭到攻击，其影响都可能波及该企业，而企业本身从未被瞄准。于是，通常的问题（“我是目标吗？”）让位于另一个问题：我的业务依赖于什么，谁可能把这种依赖变成杠杆？

这一转变对研究和实践都提出了问题。关于相互依存与胁迫的研究主要针对国家；关于供应链的研究往往笼统地看待中断；而网络风险管理框架则始终以技术边界为中心。这三类研究很少交汇，没有一类能为首席信息安全官（CISO）提供方法，以便在地缘政治环境恶化时判断哪些外部依赖值得特别关注。

1.2 研究问题与贡献

本文的核心问题如下：在什么条件下，外部依赖会成为地缘政治背景下网络风险传导的载体；地缘政治维度在其中起什么作用；网络风险治理又如何将其纳入考量？这一问题分解为三个子问题。如何刻画一项真正重要的依赖，以区别于单纯的商业关系？哪些传导机制能够区分性质不同的事件，无论其是否属于网络攻击？对于治理、风险与合规（GRC）职能，应当得出哪些结论？

本文有四项贡献。其一，区分了技术安全边界与依赖边界。其二，提出了五类依赖的类型学和五个维度的分析框架。其三，将该框架应用于六种有文献记录的情形，并为每种情形说明地缘政治关联的证据等级。其四，由此推导出面向GRC的六项操作性方向。本文采用概念性论文的路径：先综合文献，再将所提出的框架与案例相对照（Jaakkola, 2020）。本文不主张进行统计检验。

1.3 陈述的性质与行文结构

本文中的陈述并不具有同等地位，读者应当能够加以区分。取自机构报告、官方文件或审计报告的事实，作为有文献记录的发现呈现。这些发现与依赖的地缘政治之间所建立的联系，属于笔者的解释。第7节的建议则是治理方面的主张，而非实证结论。

后文安排如下。第2节将本文置于文献与监管框架之中。第3节阐述概念框架（含地缘政治维度整合矩阵，见3.6），第4节说明方法。第5节分析六个案例；第6节对其进行比较并讨论所提出的命题。第7节得出对GRC的启示，第8节阐明局限，第9节为结论。

2. 理论框架与文献综述

2.1 相互依存与胁迫

Keohane 与 Nye（1977）指出，不对称的相互依存是权力的来源：最容易摆脱这一关系的一方，对另一方拥有杠杆。Farrell 与 Newman（2019）更新了这一推理，指出全球经济网络（金融、通信、生产）并非均匀分布，而是围绕核心节点组织起来。对这些节点行使权力的国家可以由此获得两种效果：全景监控效应，即获取网络中流通的信息；以及咽喉节点效应，即能够阻止对手接入网络。云计算平台、支付系统、软件更新渠道和先进半导体制造商，恰恰具备核心节点的这些特征。

因此，这一框架提供了以组织为中心的方法所缺少的地缘政治机制。但就我们的目的而言，它也有局限：它描述的是国家的战略，而不是下游组织的处境——正是下游组织承受杠杆的施加或其附带效应。

2.2 网络、冲突与混合威胁

Rid（2012）认为，大多数网络行动属于破坏、间谍和颠覆，而非严格意义上的战争。Buchanan（2017）描述了网络空间特有的安全困境：出于防御或情报目的的入侵，可能被解读为攻击的准备，从而助长升级。近期的机构文件延伸了这些分析。欧盟理事会指出，混合威胁往往综合运用多种手段，包括信息操纵与干预、网络攻击、经济胁迫、外交胁迫和军事力量威胁，其设计意图是停留在会被视为战争行为的门槛之下（Council of the European Union, 2026）。

因此，一次行动的目标并不限于窃取数据或勒索赎金。它们可能包括搜集情报、为未来行动做准备、扰乱某一行业、中断某项服务、测试某种能力、施加压力、影响舆论或产生经济效应。还有一个解释上的困难：勒索软件可能追求经济目的，拒绝服务攻击可能来自黑客活动分子，间谍行动可能来自国家行为者，而这些类别相互重叠。对于组织而言，在必须作出决策的时刻，归因往往无从获得。

2.3 系统性风险与供应链

Perrow（1984）表明，既复杂又紧密耦合的系统会产生操作者既无法预见也无法及时阻止的事故。当代数字链条同时具备这两种属性。供应链文献由此引出了脆弱性的概念：Christopher 与 Peck（2004）将韧性与行为者之间的可见性、灵活性和协作联系起来，而 Sheffi（2005）则强调集中于少数供应商所带来的隐性成本。

数字领域还有一个特殊之处：信任关系（一次经过签名的更新、一款拥有扩展权限的监控工具）本身就成为风险的组成部分。ENISA 还指出，数字依赖扩大了攻击面，需要新一级的警惕（ENISA, 2026b）。欧盟NIS合作小组于2026年2月13日通过的ICT供应链安全工具箱，提出了识别、评估和缓解这些风险的共同方法，其中包括对高风险供应商的依赖所带来的风险（European Commission / NIS Cooperation Group, 2026）。

2.4 组织韧性

在韧性工程中，韧性指系统在扰动之前、之中和之后调整其运行，以维持所需运作的能力（Hollnagel et al., 2006）。NIST 将网络韧性分解为四个目标：预见、抵御、恢复、适应（Ross et al., 2021）。ISO 22301标准（2019）围绕影响分析和恢复策略来组织业务连续性。

这些框架提供了扎实的工具，但它们首先面向的是组织所控制的系统和流程。第三方的失效在其中通常只是影响分析中的众多情景之一，而不是一个独立的分析对象。

2.5 欧洲监管框架

NIS2 指令（2022/2555）要求相关实体采取涵盖供应链安全的风险管理措施，包括与直接供应商的关系（第21条），并在欧盟层面规定对关键供应链进行协调的风险评估（第22条）。DORA 条例（2022/2554）对金融行业走得更远：它规范ICT服务提供商所产生的风险，要求评估集中度风险，并规定退出策略。《网络韧性法案》（2024/2847）要求制造商对其产品中集成的第三方组件尽到尽职调查义务。《人工智能法案》（2024/1689）在提供者与部署者之间分配义务，使人工智能价值链成为合规的对象。ISO/IEC 27001:2022 和 ISO/IEC 27036 标准则涉及供应商关系。

这些文本有一个共同点：它们要求第三方风险得到识别和处理。然而，如何处理则留给组织自行决定，而主流实践仍然是辅以供应商登记册的合规调查问卷。替代时间、降级模式的保持以及对政治决策的暴露，在这些文本中并未作为明确的标准出现，或者只是部分出现（DORA）。

2.6 已识别的空白

可见，三种论述并存却未相交。相互依存理论解释了国家如何利用网络节点，但没有下沉到组织层面。供应链文献分析了组织的脆弱性，但缺少地缘政治胁迫的机制。网络风险管理框架为决策提供了工具，但围绕的是技术边界。本文正位于它们的交汇处：试图在组织层面上，转译武器化的相互依存对数字依赖和物质依赖产生了什么影响。

3. 概念框架

3.1 技术安全边界与依赖边界

网络风险分析最常围绕组织直接管理的资产来展开。我们把组织自身能够施加保护措施的系统和资产的集合称为*技术安全边界*。把一旦不可用或被攻陷便可能妨碍组织履行其使命的资源和行为者的集合称为*依赖边界*。两个边界部分重叠但并不重合。云服务商可能属于后者而不属于前者；一台工作站属于前者，但如果它不支撑任何关键职能，则未必出现在后者之中。

这一区分改变了向风险管理者提出的问题。问题不再仅仅是所管理的对象是否得到保护，而是要理解是什么使组织得以运转，以及什么可能使其无法运转。它延伸了业务影响分析背后的直觉，同时将其应用于组织在技术上、法律上乃至地理上都无法控制的资源。

3.2 从依赖到关键性

依赖并不等于脆弱性。几乎每个组织都依赖供应商，这种互联是数字经济的常态。当若干条件叠加时，依赖才成为战略性的风险因素：供给高度集中、难以替代、替换时间长、对技术的掌控薄弱，以及暴露于政治决策或国际紧张局势。前三者是结构性的，第四者取决于组织，最后一者取决于环境。我们用*关键性*来表示某项依赖满足这些条件的程度。

这一澄清带来方法论上的后果。供应商的国籍不足以衡量地缘政治暴露，后者必须建立在可观察的因素之上（见3.4）。

3.3 依赖的类型学

我们区分五个类别，按组织所依赖资源的性质来界定（表1）。

类别	组织所依赖的资源	典型失效模式	可能的地缘政治杠杆
软件	第三方软件、更新、监控工具	分发链被攻陷，完整性丧失	针对供应商的国家行动，对其施加的法律约束
工业（OT）	控制系统和联网的技术设备	失去控制，物理服务停止或降级	对关键基础设施的破坏
服务中介	行业的核心服务商（支付、处理、共享基础设施）	原本相互独立的组织同时无法获得服务	对核心节点施压，冲突的附带效应
硬件	原材料、元器件、制造能力	供应中断或受限	出口限制、制裁
算法	人工智能模型、算力、数据及相关服务	失去访问权限、模型被篡改、服务不可用	对算力组件的出口管制，适用的司法管辖

连锁商店的制冷控制系统，是处于情景阶段的工业依赖的一个例子。在多个场所部署的同一种技术形成了共同依赖，而技术过时、维护不足或缺少备用方案，都可能造成同时失效。由于缺少有文献记录的事件，我们没有将这一情景纳入第5节的案例。它仅用于说明这一类别。

3.4 分析框架

该框架包含五个维度（表2）。每个维度对应风险管理者可以就某项依赖提出的一个问题。前四个维度衡量风险敞口：水平越高，组织越暴露。第五个维度描述一种能力：越强，敞口越受控制。针对可替代性所提出的阈值区分三个数量级：运行层面的恢复（数日）、重新配置（数周至数月）和结构性替换（三个月以上）。这些阈值仅供参考，反映的是笔者的选择，需要按行业加以校准，例如依据影响分析中的恢复时间目标。

维度	问题	可观察的指标	解读
依赖	我们的业务离不开哪些外部资源？	关键职能及其支撑资源的图谱、合同、流程	低、中或高暴露
集中度	多个关键职能是否依赖同一供应商、同一技术或同一地理区域？	某一服务商或技术在关键职能中的占比、市场集中度、所在地	低、中或高暴露
可替代性	替换一项不可用的资源需要多长时间？	预计替换时间、迁移成本、是否存在合格的替代方案	低（一周以内）、中（一周至三个月）、高（三个月以上）暴露
传导	哪些业务、子公司、基础设施或合作伙伴会受到影响？	依赖的职能和实体数量、互联程度	低、中或高暴露
韧性	哪些职能可以在降级模式下维持，能维持多久，借助什么手段？	降级程序的存在与演练、自主运行时长、替代手段	低、部分或强能力

地缘政治维度不是作为又一个分值进入该框架的，而是通过可观察的因素来解读：贸易限制、外交紧张、产业集中、对境外基础设施的依赖、法律约束、遭受制裁的可能性、获得维护服务的困难。对于所研究的案例，它以4.4中定义的证据等级的形式单独记录。第3.6节提出了一个矩阵，用于把这一层纳入分析的每个阶段。

3.5 命题

该框架引出三个命题，第6节将其与案例相对照。它们以工作假设的形式提出：P1 和 P3 接近直觉，主要用于检验该框架能否正确地对案例排序；而 P2 将行为者的国家性质与依赖的结构性位置相对照，是最具区分力的命题。

P1。一项依赖的关键性随供给集中度和替代时间的增加而上升，无论揭示它的事件是否属于网络性质。

P2。对组织的影响严重程度，较少取决于引发中断的行为者是否具有国家性质，更多取决于该依赖在关键职能架构中所处的位置，尤其是当它拥有扩展权限或在行业中处于核心位置时。

P3。在降级模式下运行的能力调节着资源不可用与职能丧失之间的关系：该能力越强，职能丧失的持续时间就越有限。

3.6 地缘政治维度整合矩阵

3.4中的分析框架衡量结构性暴露，地缘政治解读与之分开处理（3.4、4.4、6.5）。为使这一层不止停留在原则上，我们提出一个由三部分组成的矩阵，把它纳入分析的每个阶段。它是对框架的延伸而非取代，也不改变五个维度的评级。其性质是笔者提出的方案：尚未经过实证验证（见8.1）。

第一部分：分析阶段与地缘政治问题。第一部分为分析的七个阶段（界定范围、绘制图谱、情景设定、评估、处置、测试、监测与复核）分别列出应提出的地缘政治问题、可参考的可观察因素以及预期成果。

阶段	应提出的地缘政治问题	可观察因素	成果
界定范围	如果国际环境恶化，哪些关键职能会受到影响？	所属行业、境外业务、在关键基础设施中的角色	关键职能、依赖边界
绘制图谱	我们依赖哪些外部资源，它们位于何处或在法律上归属何处？	所在地、司法管辖、二级分包商、组件来源	按五类划分的依赖清单
情景设定	每项依赖可能被施加何种地缘政治杠杆？	国家行动、制裁、出口管制、对核心节点施压	网络与非网络情景
评估	五个维度的评级是什么？单独评定的地缘政治激活程度是什么？	贸易限制、外交紧张、产业集中、法律约束、获得维护的难度	每项依赖的评估表
处置	应当减少、分散、监控还是抵消这项依赖？	替代时间、退出策略、备份协议	有理有据的治理决策

阶段	应提出的地缘政治问题	可观察因素	成果
测试	如果该资源缺失48小时、一周、一个月，这项职能会怎样？	降级程序、自主运行时长	更新后的韧性评级
监测与复核	哪些信号会触发对地缘政治层的重新评估？	新的限制措施、制裁、官方归因	复核触发条件

第二部分：地缘政治激活层。第二部分是每项依赖一张的评估表。它对三个调节因子分别评定三个等级（低、中、高）：被瞄准的概率、中断的可能持续时间，以及获得维护和更新的难度。这三个调节因子对应6.5中归于地缘政治的作用：提高被瞄准的概率、延长限制措施的持续时间、使获得维护或更新变得复杂。每项评级都附有证据等级（A至D，定义见4.4和附录A）、信号来源和复核日期，使这一层保持可修订（7.2）。对于正在分析的依赖，证据等级说明的是信号的来源，而不是过去的某起事件。将依赖类别（3.3）与其可能的杠杆交叉对照，有助于进行这一评级。

第三部分：优先级规则。结构性暴露（前四个维度的平均值，按1至3编码）和地缘政治激活程度（三个调节因子的平均值）各归为三个等级：平均值达到2.5为高，达到1.75为中，否则为低。二者的交叉给出五级刻度上的基础优先级。随后由韧性对该优先级调整一级：韧性低则上调，韧性强则下调，这与P3一致。

暴露 ＼ 激活	低	中	高
高	监控	处理	优先处理
中	接受并跟踪	监控	处理
低	接受	接受并跟踪	监控

两项保障措施源自论文本身。若激活程度为高却只有C级证据（没有确立的关联），会提示核实；只要激活程度高于低，缺少证据等级也会提示。这样可以避免预设一个尚未得到证明的地缘政治维度（4.4）。此外，高结构性暴露即使在激活程度低时也不会被归入最低等级。该矩阵并不是说地缘政治造成了风险，而是说它调节风险的优先级（P2）。

逐步操作。

1. 从依赖图谱（7.1）出发，把每项依赖归入五个类别之一（3.3）。
2. 按框架（3.4）评定四个暴露维度和韧性。
3. 评定三个地缘政治调节因子，然后填写证据等级、信号来源和复核日期。
4. 读取结构性暴露、激活程度和最终优先级，并查看一致性提示。
5. 作出决策（减少、分散、监控或抵消，7.6），并设定复核触发条件。

示例。回到7.6中的区域性分销商。框架给出：依赖高、集中度高、可替代性中（迁移需要数周）、传导高、韧性低，因此结构性暴露为高（平均值2.75）。假设没有任何地缘政治信号涉及托管服务商，而维护的获得取决于该服务商：三个调节因子分别为低、低、中，激活程度为低（平均值1.33），证据等级为C。基础优先级为“监控”，韧性低将其上调一级，成为“处理”。因此决策不是更换服务商，而是抵消：按7.6的建议记录降级模式，并测试四十八小时的不可用。如果随后有已被记录的紧张局势波及托管方，激活程度会上升，优先级也会随之上升。

工具。三个部分汇集在一个可下载的Excel工作簿中，含下拉列表、优先级自动计算、一致性提示和汇总：Excel（法语） · Excel（英语） · Excel（中文）。阈值和优先级矩阵是可修改的参数，应像可替代性阈值（3.4）一样按行业校准。

4. 研究方法

4.1 研究设计

本文结合了概念构建（第3节）和多案例研究（第5节），均为定性的文献研究。这一选择反映了问题的性质：目的不在于衡量某一现象的发生频率，而在于检验一个框架能否使性质不同的事件变得可理解。因此，案例用于探索和讨论该框架，而不是对其进行统计检验。所追求的是分析性推广，而非统计性推广，其含义取自 Yin（2018）。从案例中构建理论的逻辑遵循 Eisenhardt（1989）。

4.2 案例选择标准

案例选择以信息为导向，而不以代表性为准，遵循最大差异的逻辑（Flyvbjerg, 2006）。一个案例需满足五个条件方可入选：事件至少有一项机构来源或一手来源的记录；对组织的业务连续性产生了已证实的影响；涉及与其他案例不同的依赖类型；所涉行为者的性质各不相同（国家、犯罪、公共决策）；并且语料中至少包含一个严格意义上的网络领域之外的案例，以验证该框架是否可扩展到其他形式的依赖。

六种情形符合这些标准：NotPetya 与马士基（2017）、SolarWinds（2020）、乌克兰电网攻击（2015）、Change Healthcare（2024）、稀土限制（2025）以及与人工智能相关的依赖。最后一个案例带有前瞻性：它并非基于有文献记录的事件，并按此处理。由于缺少有来源的事件，制冷系统情景被排除在语料之外。

4.3 资料来源

语料来自公共机构和欧洲机构的报告、监管文本、官方归因声明、企业年报和公共审计报告。优先采用一手来源。专业媒体仅用于其他来源所缺少的事实性要素，并会予以标明。文中的每一项事实性陈述都对应参考文献中的一项来源。

4.4 编码

每个案例沿框架的五个维度进行分析（3.4）。前四个维度给出暴露水平（低、中、高），第五个维度给出能力水平（低、部分、强）。编码是定性的；在各案例的正文中予以论证，并在附录D中逐维度说明理由。

地缘政治维度通过一个设有四档的证据等级单独处理。A级指官方的国家归因或有文献记录的起诉。B级对应有文献记录的地缘政治背景，但没有共同的正式归因。C级表示有文献记录的系统性影响，但没有确立的地缘政治关联。D级适用于由并非网络行动的公共决策或政策所造成的中断。这种区分避免在地缘政治维度未经证明之处预设其存在，也避免在其已被证明之处否认其存在。

4.5 效度与偏差

建构效度建立在多种来源的三角验证以及对事实、解释和命题的明确区分之上。可能的偏差有三类。文献的可得性偏向大规模且被广泛评论的事件。后见之明容易使因果序列比对当事人而言更清晰。最后，编码由单一分析者完成，限制了编码者间信度。第8节将回到这些局限。

5. 案例分析

5.1 NotPetya 与马士基（2017）

2017年6月的 NotPetya 事件，为风险如何传播到最初暴露的组织之外提供了清晰的例子。这一恶意软件在被植入乌克兰使用的一条软件分发链之后，在国际上扩散。航运和物流集团 A. P. Moller-Maersk 确认其系统受到影响，业务受到干扰。该公司在2017年年报中估计，此次攻击的影响在2.5亿至3亿美元之间，主要集中在马士基航运（Maersk Line）

（A. P. Moller-Maersk, 2018）。详细的新闻报道称，网络的重建部分依赖于一份几乎是偶然保存下来的域控制器副本（Greenberg, 2018）。

其中起作用的依赖属于软件类：对更新渠道的信任。该案例的意义，与其说在于信息技术损害的范围，不如说在于一次软件攻陷如何波及一家运营依赖于数字系统、港口设施、货物流和合作伙伴之间协调的公司。内部的中断扩散到实体运营、客户和商业伙伴：一起信息技术事件变成了经济连续性问题。

地缘政治维度是确立的。英国和美国当局于2018年2月15日公开将 NotPetya 归因于俄罗斯军方（The White House, 2018），2020年对俄罗斯军事情报人员的起诉书也将该行动与他们联系起来（U.S. Department of Justice, 2020）。该案例属于A级。它表明，在区域背景下实施的行动，可以产生远远超出其最初战场的经济影响。

通过框架解读：依赖高，集中度中（广泛但局限于本地的软件），可替代性中（会计软件本身是可替换的；决定恢复进程的是信息系统整体的重建，据现有叙述约为数日至数周），传导高，韧性低，恢复部分得益于偶然的情况。对组织而言，教训是必须能够遏制一次本来未必以其为目标的攻击所产生的影响。

受影响的不只是马士基。在马士基，系统瘫痪影响了船舶协调、港口设施管理和集装箱追踪（A. P. Moller-Maersk, 2018）。圣戈班估计，此次攻击对其全年销售额的影响低于2.5亿欧元；默克表示其部分业务仍受到干扰（Help Net Security, 2017）。下表概括了该案例的经验。

维度	已记录的事实
区域地缘政治	被归因于俄罗斯军方、针对乌克兰的行动
传播载体	乌克兰本地会计软件的更新被攻陷（供应链）
全球网络安全	超出预定目标，在跨国企业网络中自动传播
经济后果	与冲突无关的企业陷入瘫痪（马士基、圣戈班、默克），实体物流链受到干扰

NotPetya 与马士基（2017）

NotPetya 与马士基（2017）堪称完美的证明和经典范例，说明一次为区域性地缘政治冲突而设计的网络攻击，如何在全球范围内造成破坏，波及那些最初甚至并未被瞄准的目标。

1. 起源：严格意义上的区域性地缘政治冲突

NotPetya 攻击最初产生于俄罗斯与乌克兰之间军事和政治紧张局势的地缘政治背景之中：

- **最初的目标：** 乌克兰的经济生态系统。恶意软件通过一款在乌克兰广泛使用的会计软件（M.E.Doc）的更新渠道植入。
- **国家归因：** 英国和美国当局已正式将该行动归因于俄罗斯军方和军事情报机构。

2. 传染机制：供应链

攻击利用软件依赖以及对更新渠道的信任，扩散到乌克兰境外：

- 只要一家跨国企业在乌克兰设有子公司、办公室，或者仅仅有使用该软件的商业合作关系，感染就可能侵入其整个全球网络。

3. 全球影响：冲突地区之外的附带损害

航运巨头 A. P. Moller-Maersk 的案例说明了全球性的外溢效应（spillover）：

- **偶然感染：** 马士基并非俄罗斯军事行动的首要或战略目标，但恶意软件自动传播到了它的全球系统。
- **从网络空间到物理世界：** 信息系统的瘫痪直接阻断了实体运营：船舶协调、港口设施管理、集装箱追踪以及全球货物流转。
- **巨大的经济代价：** 仅马士基一家，影响就达到2.5亿至3亿美元，需要对其全球信息系统几乎完全重建（只因一份偶然保存下来的备份才得以挽救）。

NotPetya 经验教训汇总表

维度	已证实的事实
区域地缘政治	旨在使第三国（乌克兰）陷入不稳定的国家级网络攻击。
传播载体	本地软件更新被攻陷（供应链）。
全球网络安全	在全球互联网上自动、不受控制地传播。
经济后果	中立的全球巨头（马士基、圣戈班、默克等）陷入瘫痪，全球实体物流链中断。

5.2 SolarWinds（2020）

2020年12月披露的 SolarWinds Orion 监控平台被攻陷事件，说明了另一种形式的依赖：建立在对软件工具及其更新机制的信任之上的依赖。软件的合法版本被篡改，嵌入了 SUNBURST 恶意代码。分发给客户的更新因而成为入侵的载体。据该供应商称，其已通知约33,000名 Orion 客户，其中不到18,000名客户被认为安装了含有恶意代码的版本（SolarWinds Corporation, 2020）。法国 CERT-FR 记录了该事件，并建议相关组织检查其版本、查找被攻陷的迹象，并考虑该平台所管理环境面临的风险（CERT-FR, 2020）。美国 CISA 则要求联邦机构断开受影响的 Orion 产品（CISA, 2020）。

问题超出了某个产品的漏洞。监控工具对其所管理的基础设施拥有广泛的可见性。对它的信任及其被赋予的权限，使其成为通向敏感资源的入口。该案例表明，供应商的合规性、更新的合法性和厂商的声誉，都不足以保证软件链的完整性：信任关系本身就是风险的组成部分。

美国当局于2021年4月正式将该行动归因于俄罗斯对外情报局（SVR），并判断软件链被攻陷使其有能力对全球超过16,000个计算机系统进行监视或破坏（The White House, 2021; CISA, 2020）：A级。

通过框架解读：依赖高，集中度高（该平台部署于数量庞大的客户处，并拥有扩展权限），可替代性高（替换一款监控工具是一个持续数月的项目），传导高，韧性低，发现较晚。组织的安全不能完全建立在对其所依赖组件的信任之上。

区域性地缘政治危机如何产生系统性后果

某一特定地区的地缘政治危机，如何对全球网络安全产生系统性后果，其影响远远超出最初的冲突地区。

核心论点

在高度互联的数字世界中，区域地缘政治从不局限于本地。由于网络空间不受物理边界的约束，针对某一地区的地缘政治紧张局势会立即成为对世界其他地区的全球网络安全风险。

这种传染通过四种传播机制实现：

1. 技术外溢效应（cyber spillover）

当一个国家对邻国发动破坏性网络攻击（恶意软件、成批的勒索软件、擦除器）时，恶意代码会在互联网上不受控制地传播。

- **接触式传播：** 为瘫痪某一区域基础设施而设计的恶意软件，渗透进与该地区互联的跨国企业的网络。
- **全球影响：** 远在数千公里之外、对冲突保持中立的企业，仅仅因为共用了位于紧张地区的一条通信线路或一台服务器，其系统就被加密或摧毁。

2. 全球供应链的不稳定化

正如 SolarWinds 案例所示，世界各地使用的大多数软件、部件和云服务都来自相互关联的价值链。

- **攻击信任点：** 为了打击某一区域性目标或对立阵营，国家级攻击者可以攻陷一家在全球运营的软件商或硬件制造商。
- **全球后果：** 只需污染一次软件更新，或造成某一关键物理部件（芯片、半导体）短缺，数以万计的全球企业的安全和业务连续性便会同时受到损害。

3. 非国家网络行为者的全球化（代理团体与黑客行动主义者）

区域紧张局势成为网络犯罪团伙和网络雇佣军的催化剂。

- **战线增多：** 黑客行动主义团体在全球范围内动员起来，支持交战一方。他们的目标不限于冲突地区，还延伸到对立各方的政治、经济和商业盟友。
- **犯罪背景噪音上升：** 处于紧张局势中的地区，国际警务合作的瓦解造成数字空间中的法外之地。网络犯罪团伙在那里肆无忌惮地活动，加大对全球私营部门的勒索软件攻击。

4. 监管冲击波与信任断裂（splinternet）

区域地缘政治迫使世界各国重新思考对外国技术的战略依赖。

- **对第三方失去信任：** 使用在卷入区域危机的国家所设计的软件、部件或云服务，会带来间谍活动、后门（backdoor）或服务中断的直接风险。
- **网络的巴尔干化：** 作为回应，各国政府实施出口限制、强化主权要求（如 NIS2 指令）和数据隔离，使全球网络碎片化，并使跨国企业的网络安全更加复杂。

小结

区域地缘政治事件	传导机制	对全球网络安全的后果
武装冲突 / 定向网络攻击	恶意代码失控传播	全球范围内中立企业的网络出现附带性瘫痪。
施压 / 制裁 / 封锁	软件商和供应商被攻陷	全球软件和硬件供应链出现大规模脆弱性。
外交紧张	代理团体和黑客行动主义团体被动员	拒绝服务（DDoS）攻击和数据泄露在全球范围内增加。
联盟破裂	法律和出口管制趋严	必须重构安全架构并隔离技术依赖。

5.3 乌克兰电网（2015）

2015年12月针对乌克兰配电运营商的攻击，是理解数字行动实体后果的核心案例。停电影响了约225,000名用户，持续数小时，据分析最长约六小时。攻击者持有合法凭据，控制了指挥界面以造成中断，随后使用 KillDisk 软件清除系统，使远程恢复变得复杂，并迫使运营商切换到手动模式（CISA, 2016; Lee et al., 2016）。

该案例凸显了信息系统、运营技术与一个地区关键职能之间的相互依存。控制系统的不可用，并不只是转化为数据丢失或应用中断：它可以直接影响一种不可或缺资源的分配。因此，民用基础设施可能在对抗背景下成为攻击目标，并成为战略施压的工具。

证据等级为A级，依据是2020年美国的起诉书，其中指控俄罗斯军事情报人员对乌克兰电网实施攻击（U.S. Department of Justice, 2020）。2016年发布的警报描述了攻击及其机制，但据笔者所知并未点名其实施者（CISA, 2016）：因此，归因仅依赖于该起诉书。

通过框架解读：依赖高，集中度中（三家配电商，架构相近），可替代性中（通过手动操作在数小时内恢复供电，但数字控制系统的恢复耗时长得多；手动操作属于韧性，而非可替代性），传导中，韧性为部分。最后一点值得强调：中断持续时间相对较短，得益于运营商保留下来的手动恢复程序。保护一项关键基础设施，意味着即使其数字系统被攻陷，也要保住其提供服务的能力。

> **乌克兰电网（2015）**
>
> 乌克兰电网（2015）这一案例研究又向前迈进了一步：我们从经济或软件依赖，转向混合战争和对一个国家的破坏。
>
> **1. 地缘政治层面：网络攻击作为战争武器**
>
> 与 Change Healthcare 案例（典型的网络犯罪，没有确凿的国家意图）不同，本案例说明网络攻击被用作战略施压和军事侵略的工具：
>
> - **以民众和经济为目标：** 网络攻击直接针对民用基础设施（电力配送），以制造混乱，影响225,000名公民的日常生活，并造成政治不稳定。
> - **地缘政治归因：** 责任被归于国家行为者（依据2020年美国起诉书，为俄罗斯军事情报人员）。网络防御由此与联合国防密不可分。
> - **混合战争理论：** 数字行动与更广泛的地缘政治紧张局势同时或先行使用，以削弱目标国家，而不立即引发传统的武装冲突。
>
> **2. 网络安全层面：对物理世界的影响（OT / ICS）**
>
> 该案例具有代表性，因为它显示了业务信息技术（IT）与工业系统 / 运营技术（OT）的融合：
>
> - **现实世界的后果：** 数字系统的不可用不仅毁坏数据，还使用户失去一种至关重要的物理资源（电力）。
> - **对备用系统的破坏（KillDisk）：** 攻击者清除了控制系统，以阻止自动或远程恢复，迫使运营回到手动操作。
> - **通过“降级模式”实现韧性：** 根本之处在于，关键基础设施的真正安全，取决于数字系统被攻陷时仍能以手动 / 降级模式继续运行的能力。
>
> **三个案例研究的对比表**

案例	风险性质	行为者 / 意图	主要教训
5.6 人工智能与算力依赖	结构性风险 / 技术依赖	国家（监管 / 主权）	与全球供应链和硬件相关的脆弱性。
5.4 Change Healthcare	集中度风险 / 单点失效	网络犯罪分子（牟利）	打击单一核心服务商就使整个行业瘫痪。
5.3 乌克兰电网	工业破坏 / 国家级定向攻击	国家行为者（地缘政治 / 军事）	必须保住实体基础设施手动运行的能力。

5.4 Change Healthcare（2024）

Change Healthcare 在2024年2月遭受的勒索软件网络攻击，显示了在关键行业中对某一数字中介高度依赖的后果。这家美国服务商尤其参与医疗相关的支付处理和行政业务。据美国政府问责局（GAO）称，此次攻击包括数据窃取，造成估计8.74亿美元的损失，并对医疗服务提供者和患者护理产生了广泛的影响（U.S. GAO, 2024）。这一数字只是一个快照：就2024年而言，其母公司 UnitedHealth Group 报告的直接应对成本超过二十亿美元（不含业务损失），并为医疗服务提供者设立了超过九十亿美元的贷款计划（UnitedHealth Group, 2025）。

该案例揭示了一种集中度风险。当某个服务商在一个行业的运转中处于核心位置时，其不可用可能同时影响在法律上和运营上仍保持独立的组织。每个组织或许都有自己的网络安全安排，却仍然面对同一个失效点。

然而，必须把系统性影响与战略意图区分开来。这是一次勒索软件攻击，据笔者所知，没有公开证据将其与国家战略联系起来（U.S. GAO, 2024）。它显示了集中化依赖的后果，但不足以确立这是一次国家层面的破坏行动：C级。

通过框架解读：依赖高，集中度高，可替代性高，传导高，韧性低。该案例对命题P2很有价值：在没有被证实的国家行为者的情况下，它造成了相当大的行业影响。

Change Healthcare（2024）

Change Healthcare（2024）完美地说明了网络安全中所谓的集中度风险和单点失效（single point of failure），这两个概念在网络安全和地缘政治上都有沉重的后果。

1. 网络安全角度：集中的陷阱

该案例显示了一种非常普遍的现象：即使每家医院或药房都妥善管理自身的信息安全，它们仍都依赖同一家核心中介来处理业务和支付。

- **多米诺效应（传导）：** 网络犯罪分子只打击一个目标（中介），就使整个行业（医疗、支付、患者护理）陷入瘫痪。
- **自主性的错觉：** 组织可以在自身安全上大量投入，但如果其所连接的外部服务商崩溃，仍然完全暴露于风险之中。
- **不成比例的成本：** 财务影响远远超出初始攻击的成本（数十亿美元的间接损失和紧急财务支持）。

2. 地缘政治角度：可被利用的战略脆弱性

即使2024年针对 Change Healthcare 的攻击是典型的、以牟利为目的的网络犯罪（勒索软件），而非国家攻击，这一情形仍揭示出一个重大弱点，敌对国家可能在危机时加以利用：

- **“咽喉节点”（chokepoints）的凸显：** 国家级对手会研究这些经济和技术依赖。在地缘政治紧张或冲突（混合战争）时，打击敌国的一两家关键行为者，就可以使其整个社会陷入不稳定，而不必逐一瞄准每个实体。

- **主权与对外国行为者的依赖：** 如果一个国家完全依赖集中的数字服务商（无论在本国境内还是在第三国），其国家安全就取决于这几家私营企业的韧性。
- **供应链的武器化：** 这类依赖表明，敌对行为者无需摧毁物理的关键基础设施（电网、水坝）就能制造混乱；阻断一家垄断性中介的数据流或资金流就足够了。

小结

数字服务的集中，把单一私营行为者的脆弱性变成了对整个国家的系统性风险。它既是重大的网络安全缺陷，也是冲突时可怕的地缘政治施压杠杆。

5.5 稀土（2025）

依赖的地缘政治并不局限于软件和网络，也涉及制造当代技术所需的材料和元器件。据国际能源署（IEA）称，2024年中国占全球用于磁体的稀土矿产量约60%，占其精炼产量的91%，占相关烧结永磁体全球制造量的94%（IEA, 2025）。因此，战略依赖不仅源于地质上的可得性，也源于工业加工能力的集中。

中国于2025年4月4日对七种重稀土、其化合物及相应磁体实施的出口管制，显示了这种集中可能带来的后果。IEA 指出，欧洲、美国及其他地区的汽车制造商遇到了供应困难，部分企业降低了产能利用率或暂时停产。2025年10月9日宣布的更广泛的管制，现在还针对含有中国产稀土的零件、组件和组装件（IEA, 2025）。

该案例并非网络攻击，但它拓宽了分析：一个组织可能拥有安全无虞的数字基础设施，却仍然容易受到切断某一不可或缺组件获取渠道的外部决策的影响。证据等级为D级，因为中断源于一项公共决策。

通过框架解读：依赖高，集中度高，可替代性高，传导高，韧性为部分，因为部分相关企业能够调整其生产而不至于完全停产。

对组织而言，这种局面可能带来以下后果。这是作者的解读，仍有待检验，且该案例并未证实：设备使用寿命延长，未修补的漏洞增多；应急采购的安全性较低，存在假冒或资质不足部件的风险；预算压力以牺牲安全为代价；数字系统物理层变得脆弱，尤其是数据中心和工业系统的备件。

稀土（2025）

一个组织可能拥有安全无虞的数字基础设施，却仍然容易受到切断某一不可或缺组件获取渠道的外部决策的影响。此时网络安全只保护组织所管理的对象，而硬件的可得性取决于其边界之外的资源。这正是技术边界与依赖边界的区别（3.1）。

可能的后果（作者的推理）

1. 设备使用寿命延长，因而漏洞增多。如果设备更新被推迟或成本更高，组织会更长时间地使用旧设备，有时没有安全补丁。这是工业环境（OT）的典型风险。

2. 应急采购的安全性较低。面对短缺，人们转向新的供应商、经纪商或灰色市场。假冒、被篡改或资质不足部件的风险上升，供应链完整性的核查则退居次要地位。

3. 预算压力。如果硬件变贵，预算可能被转向保障供应连续性，而牺牲安全。

4. 数字系统物理层的脆弱性。某些机电部件（电机、风扇、电源、存储设备）视情况可能依赖这些材料。短缺可能影响数据中心和工业系统的备件，进而影响维持服务或在事件后恢复服务的能力。

5. 更广泛的紧张局势背景。本文指出，混合威胁将经济胁迫与网络手段结合起来（2.2）。出口限制可能伴随国家行动的增多，从而提高被瞄准的概率（3.6矩阵中的第一个调节因子）。

通过框架与矩阵解读

- 硬件类别，证据等级D（公共决策，无网络归因）。
- 依赖、集中度、可替代性和传导均为高，韧性为部分。
- 在矩阵中，这属于结构性暴露强、而地缘政治激活程度有待记录的情形。因此，优先级主要来自依赖的结构（命题P2），而非攻击者的身份。

面向CISO的具体对策

- 绘制供应链经由这些部件的关键设备图谱。
- 为关键职能储备备件。
- 为继续使用的过时硬件规划补偿措施（分段隔离、强化监控）。
- 在危机之前提前遴选合格的替代供应商。
- 测试降级模式下的运行（7.3）。

5.6 人工智能与算力依赖（前瞻性案例）

先进人工智能系统的发展，建立在相互依赖的资源之上：专用半导体、算力基础设施、数据中心、能源、训练数据、模型、科学专业知识和云计算服务。对它们的控制权在国家与产业行为者之间分布不均。一个组织可能拥有自己的数据并制定自己的安全策略，却仍然依赖外部服务商来访问模型、运行处理或维持某项关键服务。

人工智能也改变了威胁态势。ENISA 观察到恶意团体越来越多地使用人工智能，主要是为了便利或放大其活动，并指出人工智能系统融入专业环境扩大了攻击面：这些系统既是工具，也是目标（ENISA, 2025; ENISA, 2026b）。此外，NIST 对针对机器学习系统的攻击类别作了形式化：针对预测式人工智能的规避、投毒和隐私攻击，以及针对生成式人工智能的供应链攻击、提示注入和滥用（Vassilev et al., 2025）。对先进计算技术的出口限制最终表明，人工智能所需的组件已成为国家安全政策的工具。2025年1月发布的所谓人工智能扩散框架（U.S. Department of Commerce / BIS, 2025）于2025年5月被BIS宣布废止，尚未生效，截至2026年年中其替代方案仍未公布，此前对先进芯片的管制仍然有效（Miller & Chevalier, 2026）。这种不稳定性本身就说明了这些杠杆的多变性质。

该案例与前述案例不同：它并非基于有文献记录的大规模中断事件。之所以保留它，是因为在任何危机发生之前，依赖的结构就已清晰可见，这使得我们能够对框架进行预防性检验。问题于是变成：我们的人工智能依赖于什么？模型、云、数据、编程接口、基础设施、供应商、图形处理器、软件链。如果模型服务商出现四十八小时的不可用，依赖它的职能能否承受？

通过框架解读：编码仅供参考：依赖为中至高（视组织而定），集中度高，可替代性高，传导中，韧性有待记录。证据等级为D级，针对算力层。

下表给出对主要阵营立场的解读。这是作者的工作假设，依据上文引用的来源，并非实证结果。

阵营	地缘政治立场	网络安全优先事项
美国	主导者、保护者	保护知识产权，控制先进计算技术的扩散
中国	寻求自主的挑战者	发展自主可控的替代方案，降低对受限先进芯片的依赖

阵营	地缘政治立场	网络安全优先事项
欧洲	依赖者、监管者	管理服务中断风险，确保使用安全（AI Act、NIS2、GDPR）

地缘政治与人工智能网络安全之间的联系

1. 美国的视角：保持领先，封闭赛场

美国如今在链条的大部分环节处于强势地位（如 Nvidia 的芯片设计，AWS / Microsoft / Google 等云巨头，以及主要模型）。

- **地缘政治利害：** 维护其技术霸权，阻止对手（主要是中国）获取尖端算力技术。这体现为对芯片和设备的严格监管和出口管制。
- **网络安全影响：**
  - **保护商业秘密：** 面临经济间谍活动和旨在窃取其知识产权（芯片、模型架构）的国家级网络攻击的高风险。
  - **保障供应链安全：** 意图（通过《芯片法案》）将制造业迁回本土，以避免依赖亚洲（尤其是台湾）脆弱的工厂。

2. 中国的视角：实现自主，绕过封锁

在美国推动下，中国面临获取最强处理器的限制。

- **地缘政治利害：** 谋求完全的战略自主，发展自己的芯片、算力基础设施和自主可控的人工智能模型，以不再依赖美国技术。
- **网络安全影响：**
  - **绕过与情报：** 更多依靠自主研究，但也依靠网络间谍活动来弥补技术差距。
  - **替代硬件存在缺陷的风险：** 使用为替代美国标准而匆忙研发的芯片或软件，可能引入新的漏洞或未被发现的安全缺陷。

3. 欧洲的视角：承受依赖，试图监管

欧洲拥有人才和研究实验室，但大规模运行人工智能严重依赖美国和亚洲的芯片以及美国的云。

- **地缘政治利害：** 寻找一条数字主权之路，避免沦为单纯的“游乐场”，或美国和中国巨头的受制客户。
- **网络安全影响：**
  - **中断或政治施压的风险：** 如果一家美国服务商中断其服务器或模型的访问达48小时（或出现监管冲突 / 制裁），欧洲企业就会陷入瘫痪。
  - **通过合规与安全的策略：** 出台严格的法规（AI Act、NIS2、GDPR）和风险评估（如上文所引的 ENISA 工作），迫使供应商保障其供应链安全，并确保系统的韧性。

小结

阵营	地缘政治立场	网络安全优先事项
美国	主导者 / 保护者	保护知识产权，控制扩散
中国	寻求自主的挑战者	发展自主可控的替代方案，绕过封锁

阵营	地缘政治立场	网络安全优先事项
欧洲	依赖者 / 监管者	管理服务中断风险，确保使用安全

5.7 传播机制：跨案例解读

六个案例使我们能够对区域性地缘政治事件如何成为远离其发生地的组织的风险这一路径作跨案例解读。这一解读是作者的分析。下列四种机制中，两种在案例中得到观察，另外两种是有待检验的假设。提出这类假设是概念框架的职责所在：它们不是研究结果。

- **技术外溢（cyber spillover）。**为区域战场设计的恶意代码失控扩散。已观察到的机制：NotPetya（5.1）。
- **全球供应链的脆弱化。**具有全球影响的软件商或供应商被攻陷，或部件的获取受到限制。已观察到的机制：SolarWinds（5.2）和稀土（5.5）。
- **非国家行为体的动员。**黑客行动主义团体或犯罪团体放大冲突战线。假设：Change Healthcare（5.4）显示了犯罪团体对整个行业的影响，但语料中没有案例记录到与冲突相关的此类动员。
- **网络碎片化与监管信任的断裂。**出口管制和主权要求趋于收紧，以致技术环境被分割。假设，部分体现在稀土管制（5.5）和适用于人工智能芯片的框架的不稳定（5.6）上；互联网本身的碎片化在语料中并未观察到。

下表将这些机制与触发事件及其对远方组织网络安全的可能后果对应起来。

区域地缘政治事件	传导机制	对远方组织的可能后果	状态
武装冲突、定向网络攻击	恶意代码失控传播	与冲突无关的企业网络出现附带性瘫痪	已观察到（NotPetya）
施压、制裁、封锁	软件商和供应商被攻陷；部件获取受限	软件和硬件供应链的脆弱性	已观察到（SolarWinds、稀土）
外交紧张	代理团体和黑客行动主义团体被动员	拒绝服务攻击和数据泄露可能增加	作者的假设
联盟破裂	法律和出口管制趋严	安全架构重构，技术依赖被隔离	作者的假设，部分得到印证（5.5、5.6）

*来源：作者的分析，基于5.1至5.6的案例。*第3行和第4行仍有待在其他案例上检验，例如与冲突相关的拒绝服务攻击行动或监管碎片化的事例。将其列于此处是为了展开讨论，这延伸了第8节所述的局限。

6. 综合与讨论

6.1 比较综合

表3再现了各案例的编码。前四个维度表示暴露，第五个维度表示能力，最后一列为4.4中定义的地缘政治证据等级。编码出自笔者，理由见附录D，仍可商榷。

案例	类别	依赖	集中度	可替代性	传导	韧性	地缘政治证据
NotPetya / 马士基（2017）	软件	高	中	中	高	低	A
SolarWinds（2020）	软件	高	高	高	高	低	A
乌克兰电网（2015）	工业（OT）	高	中	中	中	部分	A
Change Healthcare（2024）	服务中介	高	高	高	高	低	C

案例	类别	依赖	集中度	可替代性	传导	韧性	地缘政治证据
稀土（2025）	硬件	高	高	高	高	部分	D
人工智能与算力（前瞻）	算法	中至高	高	高	中	有待记录	D

6.2 横向发现

可以得出三点发现。第一，当一项依赖难以替代并且制约着某项关键职能时，它就变得尤为敏感。集中度和替代难度均高的案例（SolarWinds、Change Healthcare、稀土），也正是影响波及整个行业或一批组织而非单个组织的案例。

第二，互联放大了事件在其起点之外的后果。NotPetya 通过乌克兰的税务软件打击了一家物流公司，Change Healthcare 则波及彼此之间除了同一个中介之外毫无联系的医疗行为者。

第三，脆弱性既可能源于网络攻击，同样也可能源于产业集中，或源于商业或政治决策。把一次勒索软件攻击和一项出口限制放在同一平面上，只有在牢记它们不同地位的前提下才有意义，而地缘政治证据等级正是将这一点明确了出来。

6.3 回到命题

由于编码是由笔者借助框架本身完成的，下文所指出的吻合，更多是检验框架的内部一致性，而非对其加以验证：P1 和 P3 接近直觉，P2 是最具区分力的命题。

P1 与案例一致。集中度高且可替代性高的情形（SolarWinds、Change Healthcare、稀土），影响范围最广；而乌克兰案例中集中度、可替代性和传导均为中等，影响仍局限于三家配电商。该命题跨越了网络事件与非网络事件的界线仍然成立，因为稀土案例在没有任何网络攻击的情况下证实了它。

P2 与案例一致。Change Healthcare 在没有被证实的国家行为者的情况下造成了相当大的行业影响，而被归因于国家行为者的乌克兰攻击，持续时间有限。区分这些情形的，更多在于依赖在职能架构中的位置及其权限（SolarWinds），而非攻击者的身份。不过，行为者的性质确实会改变其他参数，例如被蓄意瞄准的概率或限制措施的持续时间，而现有语料不允许我们对此加以评估。

P3 同样得到支持。在乌克兰案例中，运营商保留了手动程序，中断仅持续数小时；马士基的恢复部分得益于偶然的情况，遭受的中断则更为深重。在稀土案例中，部分制造商得以减产而不是停产。这些比较仍然只是迹象，并不构成检验，每个案例中还有其他因素在起作用。

6.4 相对于现有框架的贡献

该框架并不主张发明这些概念：集中度、替代时间和退出策略，已经分别存在于 ISO 22301、DORA 和供应链文献之中。它的贡献在于将它们整合进一个框架，可适用于不同性质的依赖。它既不取代 ISO 22301 的影响分析，也不取代 NIS2 和 DORA 的供应商要求，而是在三个方面予以补充。它将替代时间和降级模式确立为明确且可比较的标准，而相关文本只是要求风险得到处理。它把硬件依赖和算法依赖与数字依赖置于同一框架之内处理。最后，它主张依据可观察的因素而非供应商的国籍来解读地缘政治暴露。

6.5 地缘政治增加了什么，又不能解释什么

在所观察的五个案例中，只有三个存在正式确立的地缘政治关联（A级），第六个案例为前瞻性案例。在其余案例中，地缘政治维度或者缺位（C级），或者是间接的（D级）。这一发现要求谨慎：该框架并不证明每一项关键依赖都是地缘政治工具。它表明的是，无论中断源于何处，关键依赖都是传导的载体；而地缘政治主要起调节作用：它提高被瞄准的概率，可能延长限制措施的持续时间，也可能使获得维护或更新变得复杂。因此，地缘政治解读应当是叠加在框架之上的一个分析层，而不是取而代之的标准。

7. 对GRC的启示

以下主张是笔者在前述分析基础上提出的治理建议，而非实证结论。

7.1 绘制真实依赖图谱

年度合规调查问卷仍然有用，但它描述的是供应商所声明的内容，而不是组织真正依赖的对象。第一步是从关键职能出发，逆向追溯到支撑这些职能的资源，包括二级分包商和硬件组件。这一图谱直接为框架中的依赖、集中度和传导维度提供输入。

7.2 将地缘政治维度纳入供应商分析

不应把地缘政治简化为基于供应商国籍的指标。更可取的是建立在可观察的因素之上：贸易限制、外交紧张、产业集中、对境外基础设施的依赖、法律约束、遭受制裁的可能性、获得维护的困难。这些因素作为一个独立的分析层予以记录，并随环境演变而修订。第3.6节的矩阵提出了一种记录这一层并将其与依赖优先级排序相联系的方法。

7.3 测试降级模式下的运行

任何组织都不能合理地假定自己能够阻止所有攻击。因此有必要知道，一旦某个关键供应商不可用，自己还能运转多久。覆盖四十八小时、一周和一个月时长的演练，能够区分哪些职能能够维持、哪些会停摆，并为韧性维度提供输入。乌克兰案例提醒我们，保留并维护手动程序是有价值的。

7.4 扩展业务连续性的范围

连续性计划通常处理内部故障和物理灾害。它们必须把外部数字依赖作为独立的情景纳入其中，附上预估的替代时间和备选方案，而不是将其视为一种隐含的假设。

7.5 将人工智能及其供应链视为一个依赖领域

流程中使用的人工智能服务（模型、云、数据、接口、供应商）必须出现在图谱中，并适用与其他任何依赖相同的问题，此外还要审查欧洲人工智能法规对提供者和部署者所规定的义务。

7.6 在风险治理层面整合各项职能

上述演变并不意味着CISO应当取代采购、运营、连续性或经济情报方面的负责人。它需要跨职能的治理，能够将技术风险、合同风险、产业风险和地缘政治风险联系起来。第3节的框架可以作为共同语言：五个简单的问题，各职能均可在自己的领域内回答。

一个虚构的例子说明了这一方法的用法。设想一家区域性分销商，其冷链依赖于一套由服务商托管的单一监控系统。框架给出的结果是：依赖高，集中度高，可替代性中至高（迁移需要数周），传导高（所有场所），韧性低，原因是缺少手动温度记录程序。应对措施未必是更换服务商，而可能是记录一种降级模式（人工读数、缓冲库存、备份协议），并测试四十八小时的不可用。决策仍然属于治理层面的决策：在充分了解事实的前提下，减少、分散、监控或抵消该依赖。韧性并不在于消除所有依赖，而在于识别出那些可能危及关键职能的依赖。

8. 局限与研究方向

8.1 局限

本研究有若干局限。语料规模很小：六种情形是因其多样性而非代表性被选中，不允许做统计推广。资料来源属于文献性质，质量参差不齐。企业年报或公共审计的估算并不提供可比的度量，所引用的若干金额是带有时间性的估计。编码由单一分析者完成，未做双重编码，可替代性维度的阈值仅供参考。人工智能案例具有前瞻性：它并非基于某起事件，其编码仍是暂定的。尚未与实务工作者进行验证。第3.6节的整合矩阵是尚未经过检验的方案：其阈值和优先级规则既未按行业校准，也未提交给实务工作者检验。最后，该主题演变迅速，部分近期资料可能被澄清或修订。

此外还有4.5中已提到的偏差：重大事件的文献丰富，可能呈现出比平均情况更惊人的图景，以及后见之明。

8.2 研究方向

有四个方向看来是自然的延伸。第一是通过对CISO和风险管理者的半结构化访谈进行验证，以检验该框架的易读性和实用性。第二是采用德尔菲法，按行业校准可替代性的阈值。第三是对案例进行独立的双重编码，从而可以估计编码者间信度。第四是行业应用（医疗、能源、金融），可采用匿名内部案例研究的形式，将该框架与DORA所要求的服务商登记册或现有的影响分析联系起来。

9. 结论

本文从一个简单的观察出发：保护信息系统，已不足以说明组织要运转依赖于什么。文章提出区分技术安全边界与依赖边界，把依赖分为五类，并通过五个问题加以审视：依赖、集中度、可替代性、传导、韧性。应用于六种情形后，这一框架使我们能够把性质迥异的事件放在一起，从针对软件链的国家行动，到对材料的出口限制。

这些案例表明，一项依赖的关键性首先源于供给集中度、替换的困难以及降级模式的缺失。地缘政治在其中的作用是真实的，但是间接的：它改变中断的概率和持续时间，却并非其唯一原因。这一结论是有案例支撑的工作假设，而非已经证明的结果，它有待8.2中所述的验证。

对于治理、风险与合规职能而言，其后果是实际的。要做的是绘制业务真正依赖的对象，测试资源缺失时会发生什么，并在充分了解事实的前提下，决定减少、分散、监控或抵消哪些依赖。网络韧性不仅仅在于阻止危机进入组织，还要求在危机已经发生时仍能继续运转。

参考文献

A. P. Moller-Maersk. (2018). *Annual Report 2017*. https://www.maersk.com/

Buchanan, B. (2017). *The cybersecurity dilemma: Hacking, trust and fear between nations*. Oxford University Press.

CERT-FR. (2020, updated 2021). *Présence de code malveillant dans SolarWinds Orion* (Alert CERTFR-2020-ALE-026). https://www.cert.ssi.gouv.fr/

Christopher, M., & Peck, H. (2004). Building the resilient supply chain. *The International Journal of Logistics Management, 15*(2), 1-14.

CISA. (2016). *Cyber-attack against Ukrainian critical infrastructure* (Alert IR-ALERT-H-16-056-01). https://www.cisa.gov/

CISA. (2020, December 13). *Emergency Directive 21-01: Mitigate SolarWinds Orion code compromise*. https://www.cisa.gov/

Council of the European Union. (2026, March 16). *Council adopts conclusions on advancing the EU's capacity to counter hybrid threats* (Press release 192/26).

Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 (NIS 2 Directive). *Official Journal of the European Union*, L 333, 27 December 2022.

Eisenhardt, K. M. (1989). Building theories from case study research. *Academy of Management Review, 14*(4), 532-550.

ENISA. (2025, October 1). *ENISA Threat Landscape 2025*. European Union Agency for Cybersecurity.

ENISA. (2026a, September 22). *ENISA Threat Landscape 2026*.

ENISA. (2026b, September 22). *Exploring the evolution of the cyber threat landscape* [Press release].

European Commission / NIS Cooperation Group. (2026, February 13). *Toolbox to improve ICT supply chain security*.

Farrell, H., & Newman, A. L. (2019). Weaponized interdependence. *International Security, 44*(1), 42-79.

Flyvbjerg, B. (2006). Five misunderstandings about case-study research. *Qualitative Inquiry, 12*(2), 219-245.

Greenberg, A. (2018, August 22). The untold story of NotPetya. *Wired*.

Help Net Security. (2017, August 17). *NotPetya aftermath: Companies lost hundreds of millions*. https://www.helpnetsecurity.com/2017/08/17/notpetya-losses/

Hollnagel, E., Woods, D. D., & Leveson, N. (Eds.). (2006). *Resilience engineering: Concepts and precepts*. Ashgate.

International Energy Agency. (2025). *With new export controls on critical minerals*. https://www.iea.org/

ISO. (2019). *ISO 22301:2019 Security and resilience: Business continuity management systems*.

ISO/IEC. (2022). *ISO/IEC 27001:2022*.

ISO/IEC. (2021). ISO/IEC 27036-1:2021.

Jaakkola, E. (2020). Designing conceptual articles. *AMS Review, 10*, 18-26.

Keohane, R. O., & Nye, J. S. (1977). *Power and interdependence*. Little, Brown.

Lee, R. M., Assante, M. J., & Conway, T. (2016). *Analysis of the cyber attack on the Ukrainian power grid*. SANS ICS / E-ISAC.

Miller & Chevalier. (2026, August 12). *BIS export controls 2025 year-in-review and 2026 mid-year update*. https://www.millerchevalier.com/publication/bis-export-controls-2025-year-review-and-2026-mid-year-update

Perrow, C. (1984). Normal accidents. Basic Books.

Regulation (EU) 2022/2554 (DORA). *Official Journal of the European Union*, L 333, 27 December 2022.

Regulation (EU) 2024/1689 (AI Act). *Official Journal of the European Union*, L, 12 July 2024.

Regulation (EU) 2024/2847 (Cyber Resilience Act). *Official Journal of the European Union*, L, 20 November 2024.

Rid, T. (2012). Cyber war will not take place. *Journal of Strategic Studies, 35*(1), 5-32.

Ross, R., et al. (2021). *Developing cyber-resilient systems* (NIST SP 800-160 Vol. 2 Rev. 1). NIST.

Sheffi, Y. (2005). *The resilient enterprise*. MIT Press.

SolarWinds Corporation. (2020, December 14). *Form 8-K*. U.S. Securities and Exchange Commission. https://www.sec.gov/Archives/edgar/data/1739942/000162828020017451/swi-20201214.htm

The White House. (2018, February 15). Statement from the Press Secretary.

The White House. (2021, April 15). Fact sheet: Imposing costs for harmful foreign activities by the Russian government.

U.S. Department of Commerce / BIS. (2025). Framework for Artificial Intelligence Diffusion. *Federal Register, 90* FR 4544.

U.S. Department of Justice. (2020, October 19). Six Russian GRU officers charged… [Press release].

U.S. Government Accountability Office. (2024). *Healthcare cybersecurity* (GAO-25-107755).

UnitedHealth Group. (2025). *Form 10-K for the fiscal year ended December 31, 2024*. U.S. Securities and Exchange Commission. https://www.sec.gov/Archives/edgar/data/731766/000073176625000063/unh-20241231.htm

Vassilev, A., Oprea, A., Fordyce, A., Anderson, H., Davies, X., & Hamin, M. (2025). *Adversarial machine learning: A taxonomy and terminology of attacks and mitigations* (NIST AI 100-2 E2025). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.AI.100-2e2025

Yin, R. K. (2018). *Case study research and applications* (6th ed.). Sage.

附录与声明

附录A. 地缘政治证据等级的编码规则

等级	定义	划分规则	涉及案例
A	官方的国家归因或有文献记录的起诉	至少有一个公共机构已正式将该行动归因于某一国家行为者或其代理人	NotPetya、SolarWinds、乌克兰电网
B	有文献记录的地缘政治背景，但没有共同的正式归因	机构报告确立了背景，但不存在正式归因	语料中无
C	有系统性影响，但没有确立的地缘政治关联	有文献记录的事件；没有任何证据将其与国家战略联系起来	Change Healthcare
D	由非网络性质的公共决策所造成的中断	监管、商业或出口管制措施	稀土、人工智能（算力层）

如果在两个等级之间存疑，则采用预设地缘政治关联最少的那一级。

附录B. 各案例的主要资料来源

案例	主要资料来源
NotPetya 与马士基	A. P. Moller-Maersk (2018); The White House (2018); U.S. Department of Justice (2020); Greenberg (2018); Help Net Security (2017)
SolarWinds	CERT-FR (2020); CISA (2020); SolarWinds Corporation (2020); The White House (2021)
乌克兰电网	CISA (2016); Lee et al. (2016); U.S. Department of Justice (2020)
Change Healthcare	U.S. GAO (2024); UnitedHealth Group (2025)
稀土	IEA (2025)
人工智能与算力	ENISA (2025, 2026b); Vassilev et al. (2025); U.S. Department of Commerce / BIS (2025); Miller & Chevalier (2026)

附录C. 术语表

- **CISO**：首席信息安全官（法语：RSSI）。
- **GRC**：治理、风险与合规。
- **ICT**：信息与通信技术。

- **IS**：信息系统。
- **NIS**：网络与信息安全。
- **OT**：运营技术（工业控制系统和联网的技术设备）。

附录D. 编码依据

关于可替代性和韧性的判断出自笔者；这些判断应当提交给第二位编码者复核（见8.2）。

案例	按维度的依据
NotPetya / 马士基	依赖高：会计软件的更新渠道和一个互联的信息系统整体。集中度中：该软件主要在乌克兰广泛使用。可替代性中：整体重建需数日至数周。传导高：港口和物流运营受到干扰。韧性低：恢复依赖于偶然保存下来的一份副本（Greenberg, 2018）。
SolarWinds	依赖和集中度高：监控平台安装于数千家客户处，并拥有扩展权限。可替代性高：替换一款监控工具是一个持续数月的项目（笔者判断）。传导高：客户分布于众多行业。韧性低：发现较晚。
乌克兰电网	依赖高：对配电变电站的远程控制。集中度中：三家配电商，架构相近。可替代性中：数小时内恢复供电，控制系统的恢复较慢。传导中：约225,000名用户。韧性为部分：保留了手动程序。
Change Healthcare	依赖、集中度和传导高：支付处理和医疗行政业务的核心中介。可替代性评为高（流程、合同和集成的迁移）；该编码可商榷，因为部分服务商可能在更短时间内转向其他中介。韧性低：对医疗服务提供者产生广泛影响（U.S. GAO, 2024）。
稀土	依赖、集中度和传导高：中国在稀土和磁体链条上各环节的占比（IEA, 2025）。可替代性高：在中国以外建设精炼和制造能力需要数年（笔者判断）。韧性为部分：部分制造商减产而非停产。
人工智能与算力	编码仅供参考，无有文献记录的事件：集中度和可替代性高（算力、模型、云），依赖为中至高（视组织而定），传导中，韧性有待记录。

声明

- **利益冲突：**无。
- **资助：**作者自有资金（Twagirumukiza）。
- **数据可得性：**数据来自参考文献中引用的公开来源。案例的编码见6.1和附录A。
- **生成式人工智能工具的使用：**人工智能用于校对。